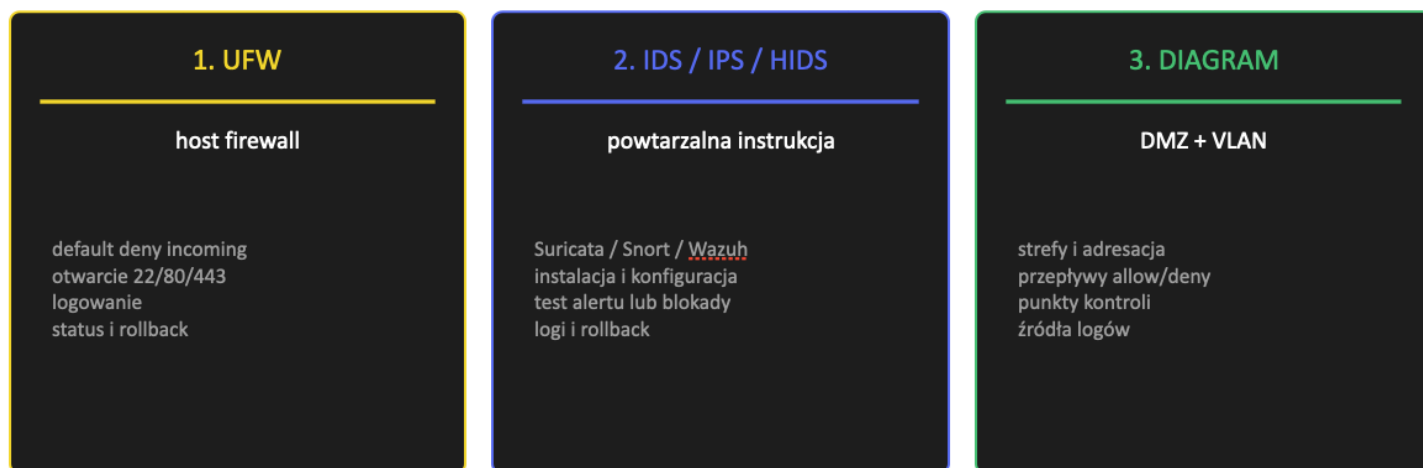


LEKCJA 7,5 – homework_UFW_IDS_IPS_HIDS_DIAGRAM

1. Konfiguracja host firewall UFW wg. reguł z zadań w LMS
2. Przygotowanie powtarzalnej instrukcji dla instalacji oraz podstawowej konfiguracji (wraz z zastosowaniem przykładowych reguł) dla narzędzi IDS lub IPS lub HIDS. Wykorzystanie jednego z narzędzi: Suricata, Snort, Wazuh. Przeprowadzenie i dokumentacja pełnej instalacji oraz konfiguracji jednej z platformy, tak aby po potencjalnej "wymianie" dokumentacji inna osoba mogła przeprowadzić instalację narzędzia. W załączniku przykładowy schemat instrukcji README.md.
3. Przygotowanie przykładowego diagramu architektury bezpieczeństwa dla sieci zdefiniowanego przez siebie organu/organizacji/przedsiębiorstwa. Skupienie się na odpowiednim wykorzystaniu (lub nie) elementów kontroli bezpieczeństwa przedstawionych na zajęciach w odpowiednich miejscach oraz ich użyteczności. Celem ćwiczenia jest całościowe spojrzenie na system.



Ad.1

Źródło: [UFW - Community Help Wiki](#)

ufw — bezpieczna kolejność konfiguracji

```
# 1. Sprawdź obecny status firewalla
sudo ufw status verbose

# 2. Polityka domyślna: blokuj wejściowy, pozwól na wyjściowy
sudo ufw default deny incoming
sudo ufw default allow outgoing

# 3. NAJPIERW dodaj SSH, zanim włączysz firewall!
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp

# 4. Włącz logowanie i aktywuj firewall
sudo ufw logging on
sudo ufw enable

# 5. Sprawdź reguły i aktywne porty
sudo ufw status numbered
sudo ss -tulpen
```

Uruchamiam UFW:

sudo ufw enable

```
vboxuser@Ubuntu:~$ sudo ufw enable
[sudo: authenticate] Password:
Firewall is active and enabled on system startup
vboxuser@Ubuntu:~$
```

Sprawdzam obecny status Uncomplicated Firewall-a:

sudo ufw status verbose

```
vboxuser@Ubuntu:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip
vboxuser@Ubuntu:~$
```

W celu wprowadzenia domyślnej polityki blokowania ruchu wejściowego i pozwolenia na ruch wyjściowy:

sudo ufw default deny incoming

```
vboxuser@Ubuntu:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
```

sudo ufw default allow outgoing

```
vboxuser@Ubuntu:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
```

#3 zaleca dodanie ssh zanim włączy firewall:

sudo ufw allow ssh

```
vboxuser@Ubuntu:~$ sudo ufw allow ssh
Rule added
Rule added (v6)
vboxuser@Ubuntu:~$
```

Pozwalam na port 22 i protokół tcp:

sudo ufw allow 22/tcp

```
vboxuser@Ubuntu:~$ sudo ufw allow 22/tcp
Skipping adding existing rule
Skipping adding existing rule (v6)
```

- otrzymałem inny wynik, ponieważ wcześniej już dodałem port 22 jako allow ssh

Zezwalam na port 80 i protokół tcp:

sudo ufw allow 80/tcp

```
vboxuser@Ubuntu:~$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)
```

Zezwalam na port 443 i protokół tcp:

sudo ufw allow 443/tcp

```
vboxuser@Ubuntu:~$ sudo ufw allow 443/tcp
[sudo: authenticate] Password:
Rule added
Rule added (v6)
```

Zezwalam na logowanie:

sudo ufw logging on

```
vboxuser@Ubuntu:~$ sudo ufw logging on
Logging enabled
```

Sprawdzam status ufw:

sudo ufw status

```
vboxuser@Ubuntu:~$ sudo ufw status
Status: active

To Action From
--
22/tcp ALLOW Anywhere
80/tcp ALLOW Anywhere
443/tcp ALLOW Anywhere
22/tcp (v6) ALLOW Anywhere (v6)
80/tcp (v6) ALLOW Anywhere (v6)
443/tcp (v6) ALLOW Anywhere (v6)
```

oraz aby ponumerował zasady:

sudo ufw status numbered

```
vboxuser@Ubuntu:~$ sudo ufw status numbered
Status: active
```

	To	Action	From
	--	-----	----
[1]	22/tcp	ALLOW IN	Anywhere
[2]	80/tcp	ALLOW IN	Anywhere
[3]	443/tcp	ALLOW IN	Anywhere
[4]	22/tcp (v6)	ALLOW IN	Anywhere (v6)
[5]	80/tcp (v6)	ALLOW IN	Anywhere (v6)
[6]	443/tcp (v6)	ALLOW IN	Anywhere (v6)

sudo ss - tulpen {ss} (socket statistics) pokaże mi informację o gniazdach sieciowych — czyli m.in. jakie porty są otwarte, na jakich adresach nasłuchują i jakie procesy z nich korzystają

-t — pokaż gniazda TCP

-u — pokaż gniazda UDP

-l — tylko porty nasłuchujące (*listening*)

-p — pokaż proces/program, który używa portu

-e — pokaż dodatkowe informacje o gnieździe

-n — pokazuj numery portów i adresy IP, bez zamiany ich na nazwy

```
vboxuser@Ubuntu:~$ sudo ss -tulpen
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
udp UNCONN 0 0 127.0.0.54:53 0.0.0.0:* users:(("systemd-resolve",pid=432,fd=18))
udp UNCONN 0 0 127.0.0.53:lo:53 0.0.0.0:* users:(("systemd-resolve",pid=432,fd=16))
udp UNCONN 0 0 127.0.0.1:323 0.0.0.0:* users:(("chronyd",pid=1282,fd=4))
udp UNCONN 0 0 0.0.0.0:5353 0.0.0.0:* users:(("avahi-daemon",pid=1075,fd=12))
udp UNCONN 0 0 [::]:323 [::]:* users:(("chronyd",pid=1282,fd=5))
udp UNCONN 0 0 [::]:5353 [::]:* users:(("avahi-daemon",pid=1075,fd=13))
tcp LISTEN 0 4096 127.0.0.53:lo:53 0.0.0.0:* users:(("systemd-resolve",pid=432,fd=17))
tcp LISTEN 0 4096 127.0.0.1:631 0.0.0.0:* users:(("cupsd",pid=1415,fd=7))
tcp LISTEN 0 4096 127.0.0.54:53 0.0.0.0:* users:(("systemd-resolve",pid=432,fd=19))
tcp LISTEN 0 4096 [::]:631 [::]:* users:(("cupsd",pid=1415,fd=6))
uid:989 ino:6001 sk:1 cgroup:/system.slice/systemd-resolved.service <->
uid:989 ino:5999 sk:2 cgroup:/system.slice/systemd-resolved.service <->
ino:14311 sk:3 cgroup:/system.slice/chrony.service <->
uid:103 ino:15525 sk:4 cgroup:/system.slice/avahi-daemon.service <->
ino:14312 sk:5 cgroup:/system.slice/chrony.service v6only:1 <->
uid:103 ino:15526 sk:6 cgroup:/system.slice/avahi-daemon.service v6only:1 <->
uid:989 ino:6000 sk:7 cgroup:/system.slice/systemd-resolved.service <->
ino:15960 sk:8 cgroup:/system.slice/system-cups.slice/cups.service <->
uid:989 ino:6002 sk:9 cgroup:/system.slice/systemd-resolved.service <->
ino:15959 sk:a cgroup:/system.slice/system-cups.slice/cups.service v6only:1 <->
```

Aby dokonać rollbacku mam kilka opcji

Najprościej zasugerować się aktualnym wynikiem numerowania wprowadzonych zasad:

```
vboxuser@Ubuntu:~$ sudo ufw status numbered
Status: active
```

	To	Action	From
	--	-----	----
[1]	22/tcp	ALLOW IN	Anywhere
[2]	80/tcp	ALLOW IN	Anywhere
[3]	443/tcp	ALLOW IN	Anywhere
[4]	22/tcp (v6)	ALLOW IN	Anywhere (v6)
[5]	80/tcp (v6)	ALLOW IN	Anywhere (v6)
[6]	443/tcp (v6)	ALLOW IN	Anywhere (v6)

I użyć usunięcia reguły posługując się tylko przyporządkowanym jej numerem: **sudo ufw delete 2** (usunie to regułę [2] 80/tcp), gdzie normalnie użyłbym polecenia: **sudo ufw delete allow 80/tcp**

Wyłączenie UFW (wyłącza też jego reguły):

sudo ufw disable

```
vboxuser@Ubuntu:~$ sudo ufw disable
Firewall stopped and disabled on system startup
```

Status:

```
vboxuser@Ubuntu:~$ sudo ufw status
Status: inactive
```

Ponowne uruchomienie (nie zostały usunięte wcześniejsze nieusunięte zasady):

```
vboxuser@Ubuntu:~$ sudo ufw status
Status: active

To Action From
--
22/tcp ALLOW Anywhere
80/tcp ALLOW Anywhere
443/tcp ALLOW Anywhere
22/tcp (v6) ALLOW Anywhere (v6)
80/tcp (v6) ALLOW Anywhere (v6)
443/tcp (v6) ALLOW Anywhere (v6)

vboxuser@Ubuntu:~$ sudo ufw status numbered
Status: active

To Action From
--
[ 1] 22/tcp ALLOW IN Anywhere
[ 2] 80/tcp ALLOW IN Anywhere
[ 3] 443/tcp ALLOW IN Anywhere
[ 4] 22/tcp (v6) ALLOW IN Anywhere (v6)
[ 5] 80/tcp (v6) ALLOW IN Anywhere (v6)
[ 6] 443/tcp (v6) ALLOW IN Anywhere (v6)
```

Ad. 3

Case study jakie wziąłem na tapetę to średnia firma drukarska 30-50 osób, która drukuje małoformatowo oraz wielkoformatowo. Posiada biuro z handlowcami, administracją, 2 osobami z Księgowości, 1 osobą HR, 3 osoby IT. Dział przygotowania do produkcji 7-10 osób, gdzie modyfikują nadestany materiał od klienta, przystosowują do druku. Dział produkcji, która ma przypisane wszystkie urządzenia drukujące i ich pracownicy zajmują się głównie serwisowaniem urządzeń oraz przygotowaniem/obsługą maszyn wielkoformatowych 5 osób.

Głównym celem było dla mnie przygotowanie zasad, co kto i czego potrzebuje, dostępny dla kogo i gdzie (uprawnienia), podział sieci, odpowiednie przygotowanie co dzieje się przy wejściu na www firmy. Zależało mi na schowaniu i odizolowaniu backendu dzięki reverse proxy z load balancerem i 2 web servery, które zapewniłyby ciągłość dostępności tej usługi www i wysoką szybkość działania.

Mechanizmy bezpieczeństwa do zastosowania:

Element | Gdzie | Po co

Firewall | Internet ↔ sieć firmy | filtrowanie ruchu przychodzącego i wychodzącego, NAT, podstawowa ochrona sieci

DMZ | pomiędzy Internetem a siecią wewnętrzną | odseparowanie publicznych usług WWW od sieci firmowej

Reverse Proxy + Load Balancer | DMZ | pośredniczenie w ruchu do serwerów WWW, terminacja HTTPS i rozdzielanie ruchu między serwery

VLAN | sieć wewnętrzna | logiczne oddzielenie biura, przygotowania do druku, produkcji, serwerów i gości

ACL / Firewall między VLAN-ami | Switch L3 (przetąacznik obsługujący warstwę 3 tworzy wirtualne interfejsy (SVI – Switched Virtual Interface) dla każdego VLAN-u) / firewall | kontrolowanie, które VLAN-y i usługi mogą komunikować się między sobą

VPN + MFA | dostęp zdalny | bezpieczny dostęp ograniczonej liczby pracowników i administratorów do sieci firmy

IDS/IPS | przy Firewall | wykrywanie i blokowanie podejrzanego lub złośliwego ruchu

Antywirus | komputery pracowników i serwery | ochrona urządzeń przed malware i innymi zagrożeniami

UFW / host firewall | serwery Linux | dodatkowa kontrola ruchu bezpośrednio na konkretnym serwerze

HTTPS / TLS | WWW i usługi wewnętrzne | szyfrowanie przesyłanych danych

Backup | NAS / oddzielna lokalizacja | możliwość odzyskania danych po awarii, błędzie lub ataku ransomware

Logowanie / SIEM | centralny system monitoringu | zbieranie i analiza logów oraz wykrywanie incydentów

Projekt segmentacji:

VLAN 10 – BIURO → administracja, księgowość, sprzedaż, HR, IT

VLAN 20 – PRZYGOTOWANIE DO DRUKU → graficy i przygotowanie projektów

VLAN 30 – PRODUKCJA → operatorzy/serwisanci, serwer wydruku + maszyny drukarskie

VLAN 40 – SERWERY → pliki klientów, system firmowy, backup itd.

VLAN 50 – GOŚCIE → TYLKO Wi-Fi, wyłącznie Internet

Zasady ruchu między VLAN-ami:

Dozwolone są tylko połączenia wymagane do działania firmy

VLAN 10 – BIURO

✓ → VLAN 40 – SERWERY

dostęp do serwera plików i usług firmowych

✓ → INTERNET

✗ → VLAN 30 – PRODUKCJA

VLAN 20 – PRZYGOTOWANIE DO DRUKU

✓ → VLAN 40 – SERWERY

pobieranie i zapisywanie plików klientów

✓ → VLAN 30 – PRODUKCJA

tylko dostęp do SERWERA DRUKU

✓ → INTERNET

✗ → bezpośredni dostęp do maszyn drukarskich

VLAN 30 – PRODUKCJA

✓ → SERWER DRUKU → MASZyny DRUKARSKIE

✗ → VLAN 10 – BIURO

✗ → VLAN 20 – PRZYGOTOWANIE DO DRUKU

✗ → INTERNET

wyjątek: tylko jeśli konkretna maszyna wymaga aktualizacji/usługi producenta

VLAN 40 – SERWERY

✓ ← VLAN 10 – BIURO

✓ ← VLAN 20 – PRZYGOTOWANIE DO DRUKU

✓ → BACKUP / NAS

✗ → VLAN 50 – GOŚCIE

VLAN 50 – GOŚCIE

✓ → INTERNET

✗ → VLAN 10 – BIURO

✗ → VLAN 20 – PRZYGOTOWANIE DO DRUKU

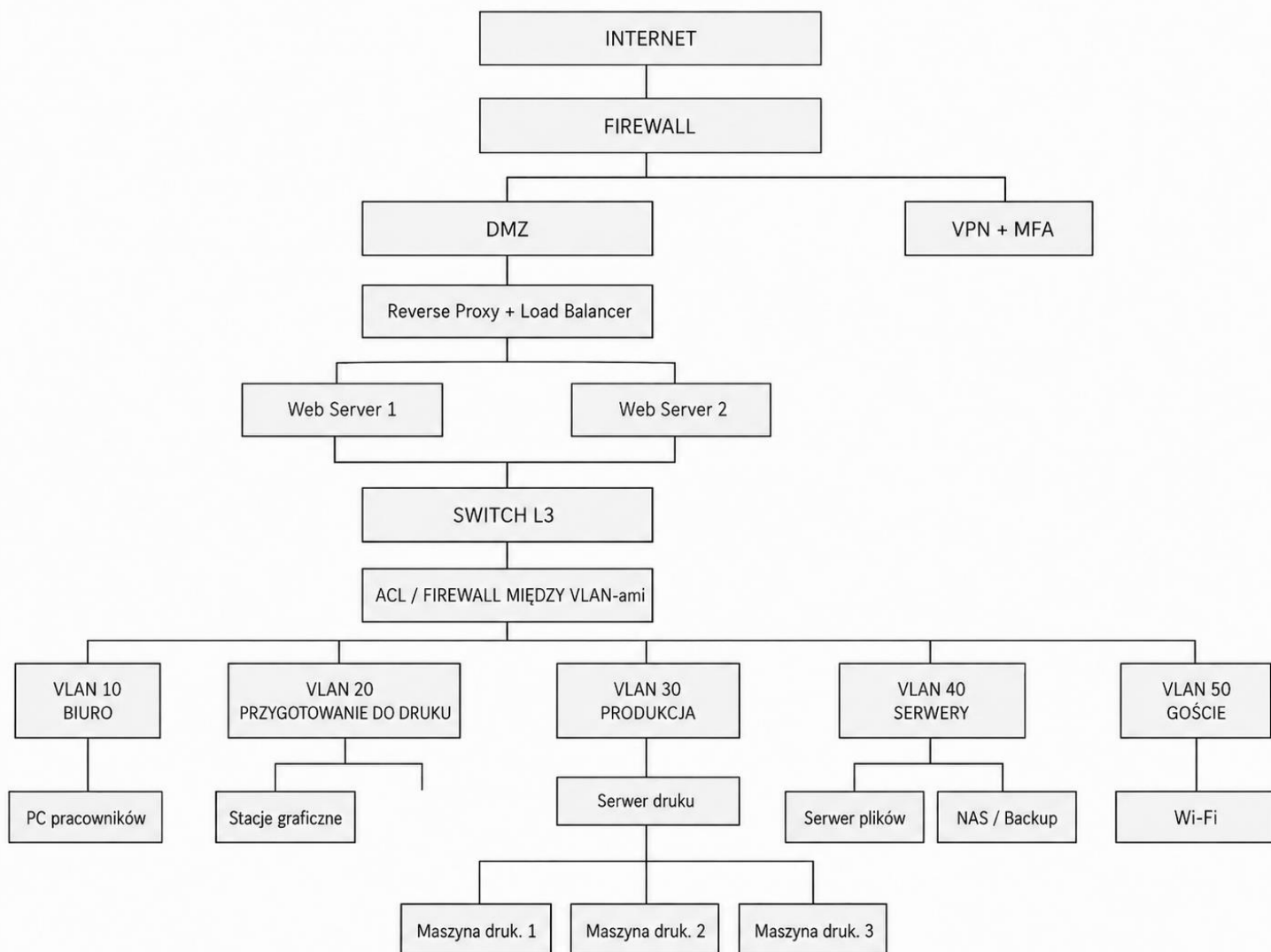
✗ → VLAN 30 – PRODUKCJA

✗ → VLAN 40 – SERWERY

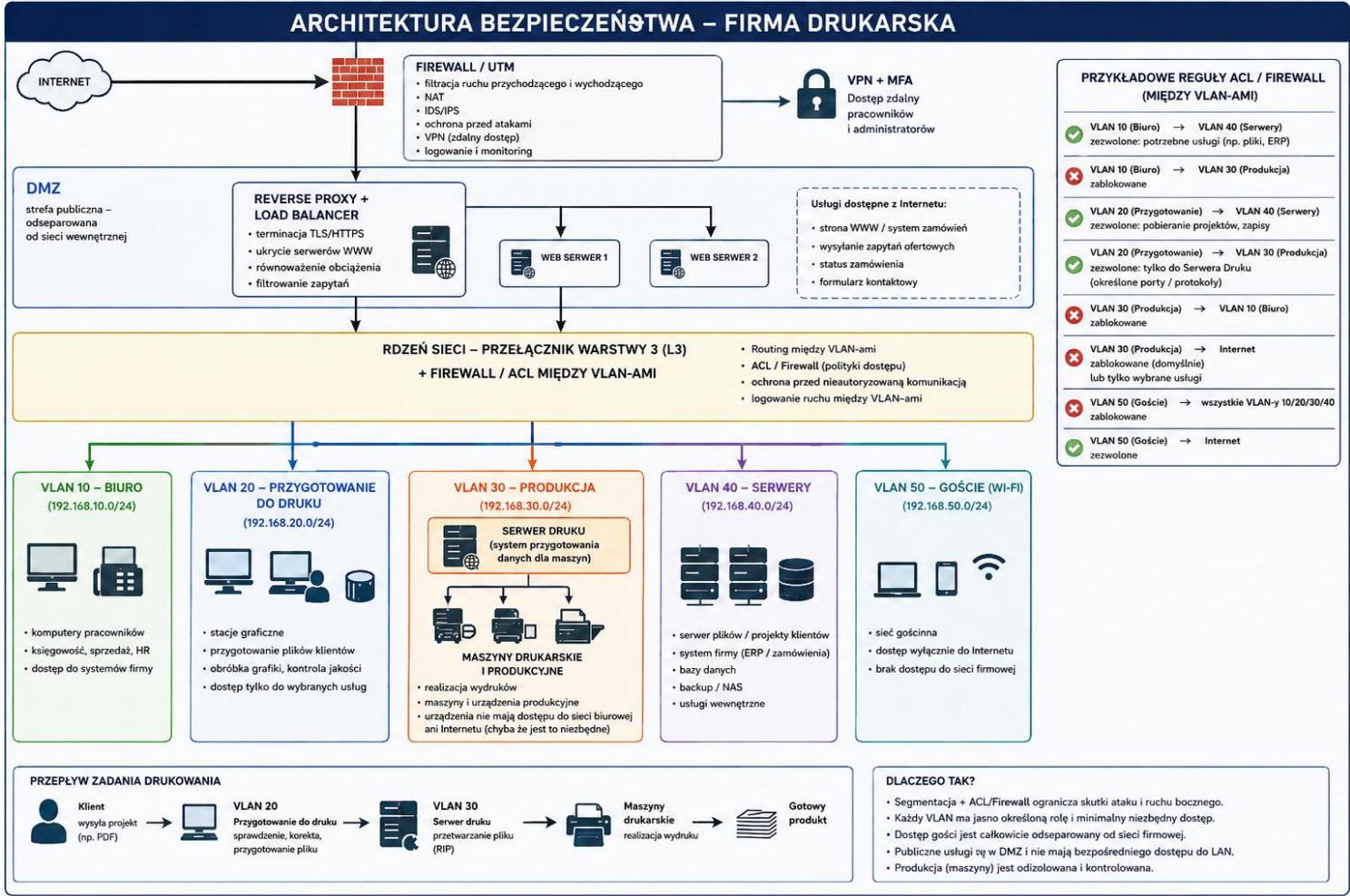
Po wstępnej segmentacji sieci, opracowałem przepływ najważniejszego z działań firmy:

[KLIENT] → [WWW / SYSTEM ZAMÓWIENÍ (np. pracownik biura)] → [VLAN 40 – SERWER PLIKÓW] → [VLAN 20 – PRZYGOTOWANIE DO DRUKU] → [ACL / FIREWALL] → [VLAN 30 – SERWER DRUKU] → [MASZYNA DRUKARSKA] → [GOTOWY WYDRUK]

Opracowałem wstępny projekt sieci dla średniej firmy drukarskiej:



Oraz korzystając z abonamentu ChatGPT Plus, w oparciu o schemat i wprowadzone zasady poprosiłem o wygenerowanie końcowego diagramu:



Ad. 2
Zostatnie prawdopodobnie udostępniony w wersji utworzonej w Visual Studio Code w osobnym pliku.